

RED TEAM METHODOLOGY

Planning, Authorisation, Conduct and Reporting of Red Team Engagements

Version 1.0

2026

Contents

RECORD OF AMENDMENTS	6
DISTRIBUTION	6
CHAPTER 1 — INTRODUCTION	6
Purpose	6
Scope	6
Applicability	6
Limits	6
Related publications	7
Terminology	7
CHAPTER 2 — RED TEAMING	7
Definition	7
Distinction from related activities	8
Limitations	8
Activities outside the remit	9
Boundary with offensive cyber operations	9
CHAPTER 3 — AIM AND OBJECTIVES	9
Aim	9
Assessment objectives	10
Measures of effectiveness	10
Prohibited measures	11
CHAPTER 4 — CATEGORIES OF ENGAGEMENT	11
Categories	11
Selection	12
Preconditions	12
Grounds for declining	12
Activities requiring specific authorisation	12
Specialised environments	13
CHAPTER 5 — AUTHORITY	13
Basis of lawful activity	13
Authorisation documents	13
Command authority and system authority	14
Independence	14
Limits of authorisation	15
CHAPTER 6 — ORGANISATION AND RESPONSIBILITIES	15
Appointments	15
Decision authority	16
Incompatible appointments	16
Establishment	17
CHAPTER 7 — CONDUCT OF AN ENGAGEMENT	18
Phases	18
Gates	18
Timescales	19
Stages of execution	19

Deconfliction	19
CHAPTER 8 — STANDING INSTRUCTIONS	20
Before commencement	20
During execution	21
Cessation of activity	21
On completion	22
Conduct of personnel	22
CHAPTER 9 — ASSESSMENT OF EFFECTIVENESS	22
Principle	22
Measures	22
Reporting to command	23
Maturity	23
CHAPTER 10 — RESOURCES AND COMMAND COMMITMENTS	24
Resources	24
Annual programme	24
Command commitments	24
Risks accepted	25
CHAPTER 11 — GOVERNANCE	25
Structure of the publication	25
Review	26
Exceptions	26
Escalation	26
Independent assurance	26
LEXICON	27
Abbreviations	27
Terms and definitions	27

RECORD OF AMENDMENTS

Version 1.0

Amendment	Date	Inserted by	Summary
Original issue			

DISTRIBUTION

Held by the Approving Authority, the Head of Red Team, the Legal Adviser, the Security Authority and all red team personnel. The head of the defensive element holds this publication but not the documents of any engagement.

CHAPTER 1 — INTRODUCTION

Purpose

1.1 This publication establishes the methodology for the planning, authorisation, conduct and reporting of red team engagements. It defines the appointments involved, the authority required, the sequence of activity, the constraints on that activity, and the basis on which effectiveness is judged.

1.2 It is a governing publication, not a technical manual. It describes how engagements are controlled. It does not describe how techniques are executed. Technical direction is issued separately in the annexes listed at paragraph 1.9.

Scope

1.3 This publication applies to all assurance activity conducted against information systems with the consent of the authority responsible for those systems, whether those systems belong to the issuing organisation or to another organisation assessed under mandate.

1.4 It applies equally to covert engagements, open collaborative work with defensive elements, and participation in exercises.

Applicability

1.5 This publication is binding on all personnel conducting or supporting red team activity, and on the appointments that authorise and control it.

1.6 Compliance is a condition of authorisation. Activity conducted outside this methodology is unauthorised activity, with the consequences set out at paragraph 5.2.

Limits

1.7 This publication governs assurance activity only. It confers no authority in relation to operations conducted against an adversary's systems. The boundary is set out at Chapter 2, paragraphs 2.11 to 2.14.

1.8 Approval of this publication authorises no activity against any target. Authority for activity is established engagement by engagement under Chapter 5.

Related publications

1.9 Annexes A to G form the common engagement control set. Annex H applies according to the category of activity, Annex I applies only to the specialised environments it names, Annex J governs the standing capability, and Annex K records applicability and source provenance. The annexes are issued under the authority of the Head of Red Team and may be amended without amendment to this publication.

Annex	Title
A	Roles and Decision Rights
B	Rules of Engagement Standard
C	Engagement Lifecycle
D	Planning and Threat Profiling
E	Execution and Tradecraft
F	Reporting and Metrics
G	Legal, Safety and Data Handling
H	Categories of Engagement
I	Specialised Environments
J	Capability: Tooling, Laboratory and Training
K	Basis and Sources

1.10 Pro formas T01 to T12 are issued with this publication for use during an engagement. Each pro forma shall be completed and retained as part of the engagement record.

Terminology

1.11 The following conventions apply throughout this publication and its annexes.

Term	Meaning
shall	A mandatory requirement. Deviation requires written approval from the Approving Authority under paragraph 11.4.
should	A strong requirement. Deviation requires a recorded justification in the engagement plan.
may	Permitted at the discretion of the appointment named.

1.12 Terms of art are defined in the Lexicon.

CHAPTER 2 — RED TEAMING

Definition

2.1 A red team is an element with sufficient organisational and functional independence to challenge an organisation from the perspective of an adversary in order to improve that organisation's

effectiveness. An internal red team is not assumed to be structurally independent; the controls at paragraph 5.9 preserve the independence of its decisions, evidence and reporting.

2.2 Red teaming is the emulation of the tactics, techniques and procedures of a real adversary against live systems, personnel and processes, under authorisation, in order to measure the effectiveness of the defences opposing that adversary.

2.3 The object of a red team engagement is not to obtain access. The object is to establish what the defending organisation does when access is obtained.

Distinction from related activities

2.4 Red teaming is routinely confused with other forms of security testing. The distinction governs what a customer receives, and shall be established in writing before an engagement is accepted.

Activity	Question answered	Product	Defensive awareness
Vulnerability assessment	Which weaknesses exist across the estate?	An inventory of weaknesses	Known
Penetration test	Can a defined system be compromised?	Demonstrated weaknesses in that system	Known
Purple team exercise	Is adversary behaviour detected when it occurs?	Validated detections	Full participant
Red team engagement	Can an adversary achieve mission impact without being stopped?	An attack path and an assessment of the response to it	Normally withheld from the assessed defensive element; the Control Team is informed
Adversary emulation	Are the defences effective against a named threat actor?	Coverage against that actor's documented behaviour	Open or covert by design

2.5 A penetration test measures the target system. A red team engagement measures the defending organisation. A customer seeking an inventory of weaknesses requires a vulnerability assessment, and a red team engagement will not satisfy that requirement.

Limitations

2.6 A red team engagement provides assurance only in respect of the target space, techniques and period defined in its authorisation. Absence of a finding is not evidence of absence of weakness.

2.7 An engagement emulates a stated level of adversary capability. It does not represent the capability of every possible adversary.

2.8 Techniques excluded on grounds of safety, legality or capability are recorded in the threat profile. An adversary unconstrained by those limits may achieve outcomes not demonstrated by the engagement.

Activities outside the remit

2.9 The red team does not perform the following functions.

- a. Inventory-based vulnerability scanning of an estate.
- b. Certification of compliance against any control framework. An engagement produces evidence of performance under attack, not evidence of compliance.
- c. Incident response. Where a genuine intrusion is identified, activity ceases and the matter is transferred under paragraphs 8.15.f and 8.23.
- d. Assessment of individual personnel. Findings describe systems and processes. Where the action of a person is material, it is described by appointment and never by name.

Boundary with offensive cyber operations

2.10 An organisation may hold both an assurance capability and an operational effects capability. The two employ comparable skills, similar tooling and common terminology. They are separate functions under separate authority and shall not be conflated.

	Assurance (this publication)	Operational effects
Object	Measurement and improvement of own defences	Achievement of an effect against an adversary
Target	Own systems, or systems assessed under mandate	An adversary's systems
Basis	Consent of the responsible system authority	A separate legal framework
Governed by	This publication	Not this publication

2.11 No activity conducted under this publication shall touch a system outside the authorised target space recorded in a signed Rules of Engagement and Letter of Authorisation. There is no exception on grounds of operational necessity and no provision for verbal override.

2.12 Infrastructure, tooling and personnel assigned to assurance activity shall not be employed on operational effects activity, and the converse. Common use invalidates the authorisation model of both.

2.13 Capability developed for assurance may be transferred to the operational function only by a process approved by the Approving Authority. Informal transfer is prohibited. Where an individual serves in both functions, that individual operates under one function at a time and records which.

2.14 Any direction to employ this capability outside its authorised target space shall be refused and reported to the Approving Authority, irrespective of the seniority of the originator. Refusal on this ground is a requirement of this publication and attracts no consequence for the individual.

CHAPTER 3 — AIM AND OBJECTIVES

Aim

3.1 The aim of red team activity is to measure and improve the ability of an organisation to prevent, detect, respond to and recover from attack by adversaries that realistically threaten it,

and to convert the results into defensive improvements that are verified to completion.

3.2 Two elements of that aim govern the conduct of engagements. First, adversaries are selected on the basis of realistic threat and not on the basis of technical interest. The baseline is set by the threat the organisation actually faces, recorded in the threat profile at Annex D. Second, an engagement that concludes on delivery of a report has produced a document and not an improvement. Verification of remediation forms part of the engagement and is addressed at Chapter 7, phase 7.

Assessment objectives

3.3 Every engagement shall advance at least one of the following four objectives, and the objective selected shall be recorded in the Rules of Engagement.

	Objective	Question answered	Principal measure
1	Protect	Do preventive controls stop the emulated adversary?	Techniques blocked as a proportion of techniques attempted
2	Detect	Are usable telemetry and a relevant alert generated where the adversary is not stopped?	Applicable actions producing telemetry and alert; time to alert
3	Respond	Do personnel and procedures examine, contain and escalate correctly within acceptable time?	Time to examination and containment; correctness of action
4	Restore	Can the affected capability be recovered to a trusted state?	Time to recover; integrity of recovery

3.4 Immature programmes assess only the first objective, which is the most straightforward to demonstrate. The greatest return in the early stages of a programme is obtained from the second and third.

Measures of effectiveness

3.5 Red team activity is judged on the improvement of the defence and not on the achievement of the red team. The following indicate an effective capability.

- a. Validated detection coverage improves for comparable, threat-relevant actions.
- b. Time to alert, examination, containment and recovery improves for comparable actions.
- c. Findings are closed by passed retest, read across where appropriate, and do not recur under genuinely comparable conditions.
- d. Defensive elements request engagements.
- e. Command employs the resulting reporting in resourcing decisions.

3.6 The following indicate an ineffective capability, irrespective of the number of objectives achieved during engagements.

- a. Findings recur between engagements.
- b. Reports are received and no change follows.
- c. Defensive elements first learn of an engagement from its report.

- d. Outcomes are discussed as a contest between elements.
- e. Activity cannot be reconstructed from the red team's own records.

Prohibited measures

3.7 The following shall not appear in any red team product, briefing or dashboard.

- a. Any measure expressed as a success or win rate for the red team.
- b. Any count of occasions on which a defensive element failed to detect activity.
- c. Time to obtain administrative control of a domain, presented as an achievement.
- d. Counts of systems compromised or weaknesses identified, presented without reference to impact.
- e. Comparison between defending elements, shifts or individuals.

3.8 Measures of this kind cause the organisation to conceal problems. Where command requests such a measure, the equivalent measure of defensive performance shall be offered in its place.

CHAPTER 4 — CATEGORIES OF ENGAGEMENT

Categories

4.1 Four categories of engagement are recognised. All are conducted under this publication. Variations particular to each are set out at Annex H.

	Category	Customer	Normally covert
SL-1	Internal assessment of own systems, personnel and processes	Own command	Yes
SL-2	Assessment of another organisation under mandate or agreement	The assessed organisation and the mandating authority	Yes
SL-3	Red team element within a structured exercise	The exercise director	Scripted
SL-4	Purple team activity conducted openly with defensive elements	Own defensive element	No

4.2 Categories are introduced in the order SL-4, SL-1, SL-3, SL-2. Assessment of another organisation carries the greatest legal and institutional risk and is the least tolerant of procedural error. It shall not be undertaken until the procedures in this publication are established in practice and the legal framework at Annex G is confirmed.

Selection

4.3 The category of activity shall be established against the customer's requirement before an engagement is accepted.

Customer requirement	Activity
An inventory of weaknesses across an estate	Vulnerability assessment; not a red team task
Demonstration that a defined system can be compromised	Penetration test
Confirmation that detections function	Purple team exercise (SL-4)
Determination whether a realistic attack achieves impact undetected	Red team engagement (SL-1 or SL-2)
Training of personnel under operational pressure	Exercise (SL-3)

Preconditions

4.4 An engagement conducted against an organisation possessing no detection capability produces a foreseeable result: all objectives achieved, no activity detected, and a report recommending the introduction of logging. That result is available without an engagement.

4.5 Before an SL-1 or SL-2 engagement is accepted, the target organisation shall be confirmed to hold the following.

- a. Centralised collection of logs from endpoints and identity services.
- b. An appointment responsible for the review of alerts, with defined hours of coverage.
- c. A documented incident response procedure.
- d. Sufficient record of asset ownership to route a finding to an owner.
- e. Evidence that a previous assessment has been remediated.

Grounds for declining

4.6 Where three or more of the preconditions at paragraph 4.5 are absent, the engagement should be declined in writing and a purple team exercise or tabletop recommended in its place. The recommendation and its basis shall be recorded on pro forma T01.

4.7 An engagement shall be declined where authority is unclear, where scope cannot be bounded, where the appointments at Chapter 6 cannot be filled, or where the activity cannot be conducted safely.

Activities requiring specific authorisation

4.8 The following require specific written authorisation in the Rules of Engagement and a risk acceptance recorded by the Approving Authority. The authorisation applies only where Annex B classifies the action as conditional. An absolute prohibition cannot be waived by the Approving Authority or by any engagement signatory. Legal and provider requirements remain independently applicable.

- a. Social engineering of personnel, by any vector. Additional constraints govern permitted pretext themes, excluded individuals, handling of captured credentials, and the reporting of results by rate rather than by individual.

- b. Physical entry, bypass of physical controls, and on-site pretexting. These require a separate Letter of Authorisation and prior notification of site security.
- c. Controlled availability or resource-exhaustion testing. Genuine destructive action is an absolute prohibition.
- d. Any activity affecting a third party, supplier or hosted service, but only with that party's direct permission and compliance with current provider conditions.

Specialised environments

4.9 Where the scope includes a classified or air-gapped network, a mission, command or weapon system, a deployed or tactical network, installation operational technology, or an allied or coalition system, the additional controls at Annex I apply and are mandatory. The applicability check at Annex I is conducted during phase 0.

CHAPTER 5 — AUTHORITY

Basis of lawful activity

5.1 Red team activity may engage criminal, civil, regulatory, contractual, employment and data protection law. Written, target-specific authorisation from an authority competent to give it is necessary, but may not by itself satisfy every applicable requirement. The legal adviser shall identify the complete basis for each engagement under Annex G.

5.2 Defective or incomplete authority may expose both the organisation and individual participants. An operator therefore holds an unconditional right to refuse activity on grounds of defective authority, and that refusal attracts no adverse consequence.

Authorisation documents

5.3 Three documents are required. Each performs a distinct function. Activity shall not commence until all three are in force.

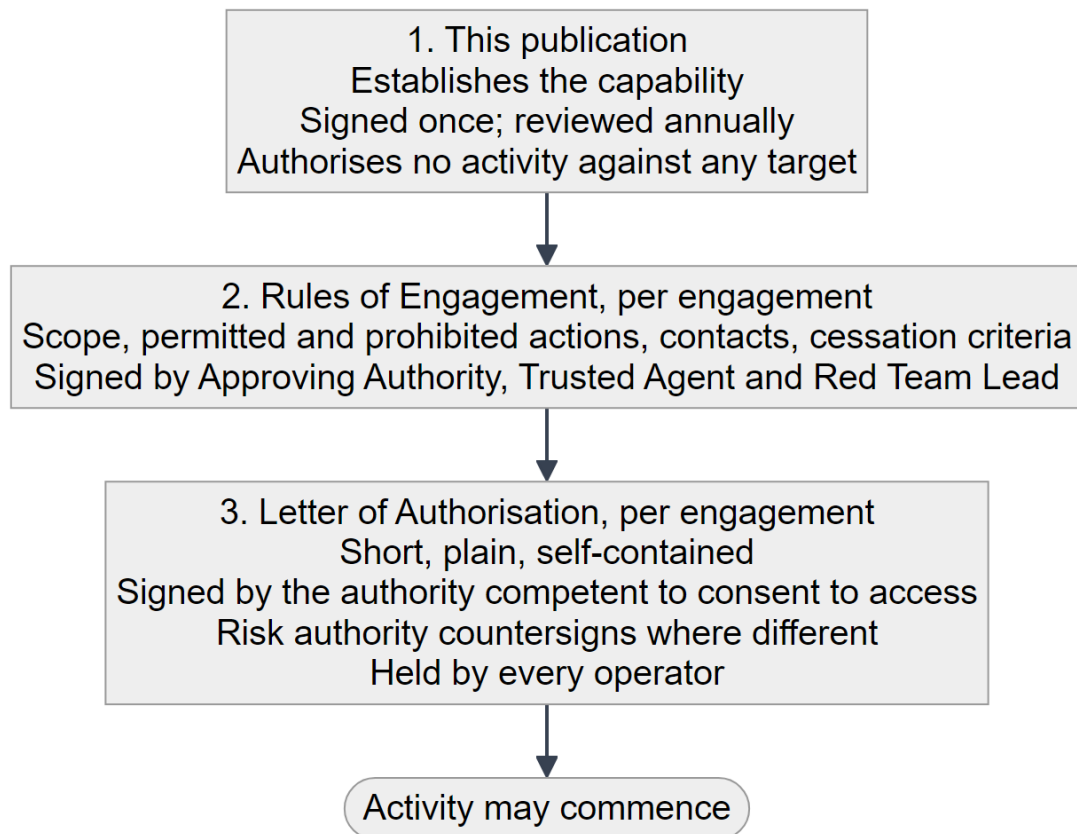


Figure 1. Authorisation chain

5.4 The separation between this publication and the engagement documents shall not be collapsed. A standing authority to conduct activity against unspecified targets is indistinguishable, on subsequent examination, from an absence of authority.

5.5 The Rules of Engagement standard is at Annex B. The pro forma is at T02. The Letter of Authorisation pro forma is at T10.

Command authority and system authority

5.6 Command authority and system authority are distinct.

- a. Command authority is the power to direct that an assessment be conducted.
- b. System authority is the power to consent to access to a particular system.

5.7 A tasking order establishes the first. It does not of itself establish the second unless the instrument creating the mandate expressly confers it. Where the two are held by different bodies, both are required. System authority records the required consent to access; it does not replace any other legal, contractual or provider requirement. The position shall be established in writing before Chapter 7, phase 1 is complete.

Independence

5.8 Assessment independence and the chain of command are in tension. A red team subordinate to an officer whose capability it assesses will moderate its findings. This occurs through the ordinary operation of hierarchy and not through dishonesty, and it is not evident to those involved.

5.9 The following controls are mandatory and shall be recorded in the Rules of Engagement for every engagement.

- a. A written right of direct report to the Approving Authority, bypassing any intermediate commander.
- b. The Approving Authority for an engagement shall be outside the chain of command being assessed.
- c. Reports shall be delivered to the Approving Authority and to the assessed commander simultaneously. There shall be no prior sight and no opportunity to amend findings before issue.
- d. Severity assessments may be disputed, and the dispute recorded. They shall not be amended without record.
- e. The Head of Red Team shall not be appraised by a commander whose capability the red team assesses.
- f. Refusal of activity on legal, safety or ethical grounds is protected and escalates directly to the Approving Authority.

5.10 Sub-paragraph 5.9.c is the control most commonly eroded, ordinarily by a request for sight of a report before issue. Such a request shall be declined. The legitimate requirements it represents are met by simultaneous delivery, by a right of written reply appended to the report, and by record of any disputed severity assessment.

Limits of authorisation

5.11 Approval of this publication authorises the maintenance of a standing capability, the preparation of engagements, and the holding of engagement data under the controls at Annex G. It does not authorise activity against any target.

CHAPTER 6 — ORGANISATION AND RESPONSIBILITIES

Appointments

6.1 One standing appointment and five engagement appointments govern red team activity. Full responsibilities are at Annex A.

Appointment	Responsible for	Shall not be
Head of Red Team (standing)	The capability: personnel, tooling, standards, the annexes, and quarterly reporting to command.	Appraised by a commander whose capability the red team assesses
Approving Authority	Acceptance of operational risk. Signature or countersignature of the Letter of Authorisation.	An officer whose capability the engagement assesses
Trusted Agent (Control Team Lead)	Control of the engagement and its safety. Holds unilateral authority to suspend or terminate.	A member of the red team, or of the defensive element being assessed
Red Team Lead	Conduct of one engagement, its safety, and the accuracy of its report.	The Trusted Agent
Operator	Own actions and own records.	Not applicable

Appointment	Responsible for	Shall not be
Defensive element	Normal defence of the organisation.	Informed in advance, in a covert engagement

The Head of Red Team may act as Red Team Lead on a given engagement. The two appointments are distinct: the first is permanent and owns the capability, the second is appointed for one engagement and owns its conduct.

6.2 The first duty of the Trusted Agent is the prevention of irreversible harm. That authority is unilateral, requires no justification, and is exercised without notice. No person shall be criticised for a suspension that proves to have been unnecessary.

Decision authority

6.3 The following decisions rest with the appointments shown.

Decision	Appointment
Whether an engagement proceeds	Approving Authority
Objectives and scope	Approving Authority, on the advice of the Trusted Agent
Consent to access and signature of the Letter of Authorisation	System authority; the Approving Authority countersigns where different
Extension of scope, or authorisation of a prohibited action, during an engagement	Approving Authority
Determination whether observed activity is red team or genuine	Trusted Agent
Suspension or termination of the engagement	Trusted Agent, unilaterally
Approval of a high-risk action	Trusted Agent
Refusal to commence or continue on grounds of safety or authority	Red Team Lead, and any operator
Assessment of finding severity	Red Team, subject to recorded dispute
Closure of a finding	Red Team, following a passed retest
Acceptance of a risk in place of remediation	Approving Authority, in writing, with a review date

6.4 During execution, accountability for suspension rests with the Trusted Agent and not with the Red Team Lead.

Incompatible appointments

6.5 The following combinations of appointment are prohibited.

Combination	Reason
Red Team Lead and Trusted Agent	The appointment creating the risk would assess whether that risk is acceptable

Combination	Reason
Any red team member and Approving Authority	Self-authorisation, which is indistinguishable in law from absence of authorisation
Trusted Agent and a member of the assessed defensive element, in a covert engagement	Prior knowledge invalidates the result for that element
Author of a report and its sole reviewer	No independent verification of the claims made
Approving Authority within the chain of command assessed	Risk cannot be impartially accepted on behalf of a capability the engagement judges

6.6 The combinations at paragraph 6.5 are non-waivable. If the appointments cannot be separated, the activity shall be re-scoped as an open or purple team exercise, or a qualified external person shall fill the conflicting appointment. It shall not proceed as a covert red team engagement. Limited establishment does not itself constitute a compensating control.

Establishment

6.7 Establishment is scaled to the activity. The Approving Authority, system authority, Trusted Agent and any supporting Control Team are outside the red team establishment.

Delivery establishment	Activity permitted	Conditions
Two personnel	SL-4 purple activity, laboratory validation and tightly scoped open assumed-breach work	Separate Trusted Agent and Approving Authority; both delivery personnel present; independent review obtained outside the delivery cell
Three to five personnel	Covert SL-1 work and routine threat-led engagements	A Red Team Lead and at least two operators are assigned; a deputy and independent reviewer are available; no member performs defensive or incident-response duties for the same engagement
Six to nine personnel	Sustainable programme with specialisation and parallel work	Appointments can be separated and the programme at paragraph 10.4 can be maintained

6.8 Two conditions govern sustainability at every tier.

- a. No critical capability shall depend permanently on one individual. At the two- and three-person tiers, backup may be supplied by a qualified person outside the delivery cell under the same clearance, confidentiality and conflict controls.
- b. Twenty per cent of establishment time should be reserved for capability development, laboratory validation, remediation support and retest. A team used continuously for new engagements reproduces the same findings by the same techniques and leaves earlier findings unverified.

CHAPTER 7 — CONDUCT OF AN ENGAGEMENT

Phases

7.1 Every engagement follows eight phases. Small engagements compress phases. No phase is omitted. Detail, including entry and exit criteria, is at Annex C.

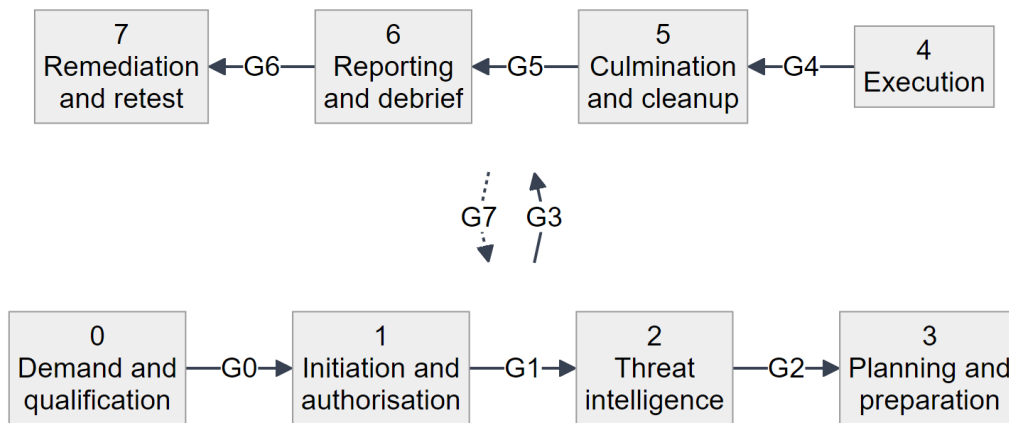


Figure 2. Engagement lifecycle

Phase	Purpose	Concludes when
0 Demand and qualification	Determine whether the engagement should proceed and whether red teaming is the correct instrument	The customer states the decision the result will inform
1 Initiation and authorisation	Establish verified authority, legal review, boundaries and safety controls	Rules of Engagement and Letter of Authorisation are signed and contacts verified by telephone
2 Threat intelligence	Determine which adversary is emulated, and on what basis	A named adversary is justified against current reporting
3 Planning and preparation	Achieve readiness before the environment is entered	All tooling is tested in the laboratory and activity can be suspended within fifteen minutes
4 Execution	Conduct the scenario within the Rules of Engagement	Objectives are achieved or the period expires
5 Culmination and cleanup	Return the environment and engagement infrastructure to the agreed state	Every modification is reversed, accepted or transferred and independently verified
6 Reporting and debrief	Convert activity into decisions	Every claim is evidenced and a reviewer who did not execute has signed
7 Remediation and retest	Establish that the organisation has improved	Critical and high findings are retested and verified

Gates

7.2 Each phase concludes at a gate. A gate is a decision taken by a named appointment, which either passes the engagement forward or returns it.

7.3 Gate G1 is absolute. Another gate may be passed conditionally only where its decision owner records the unmet criterion, risk, compensating control, owner and deadline. A conditional pass cannot cure defective authority, invalid provider or third-party permission, an absolute prohibition, an unresolved cessation criterion, or an unsafe plan. Activity conducted before Gate G1 is unauthorised activity.

7.4 Phase 7 distinguishes an assurance capability from an expenditure. A finding is closed by a passed retest and not by the closure of a task.

Timescales

7.5 The following are planning figures for a scoped internal engagement.

Phases	Elapsed
0 to 3, demand to readiness	Three to five weeks, governed principally by signature
4, execution	Two to four weeks
5 to 6, cleanup to report	One and a half to two weeks
7, remediation and retest	One to three months, periodic
Demand to delivery of report	Six to nine weeks

7.6 Execution constitutes less than half of an engagement. A requirement expressed as a two-week engagement is a six-week engagement containing two weeks of execution.

7.7 A formal TIBER, DORA or CBEST test follows the current scheme's duration, deliverables and authority process, which may be materially longer than these internal planning figures. Scheme timescales are not imported into ordinary internal work and shall not be shortened where the scheme applies.

Stages of execution

7.8 Execution proceeds in three stages. The stages describe the operational sequence and are distinct from the tactics at Annex D, which describe individual behaviours.

Stage	Object
Get In	Establish a foothold
Stay In	Render access reliable and survivable
Act	Achieve the objective and demonstrate impact

Deconfliction

7.9 Deconfliction establishes whether observed activity originates from the red team or from a genuine adversary. It guards against two failures: expenditure of defensive effort on exercise activity, and dismissal of a genuine intrusion as exercise activity. The second is the more serious.

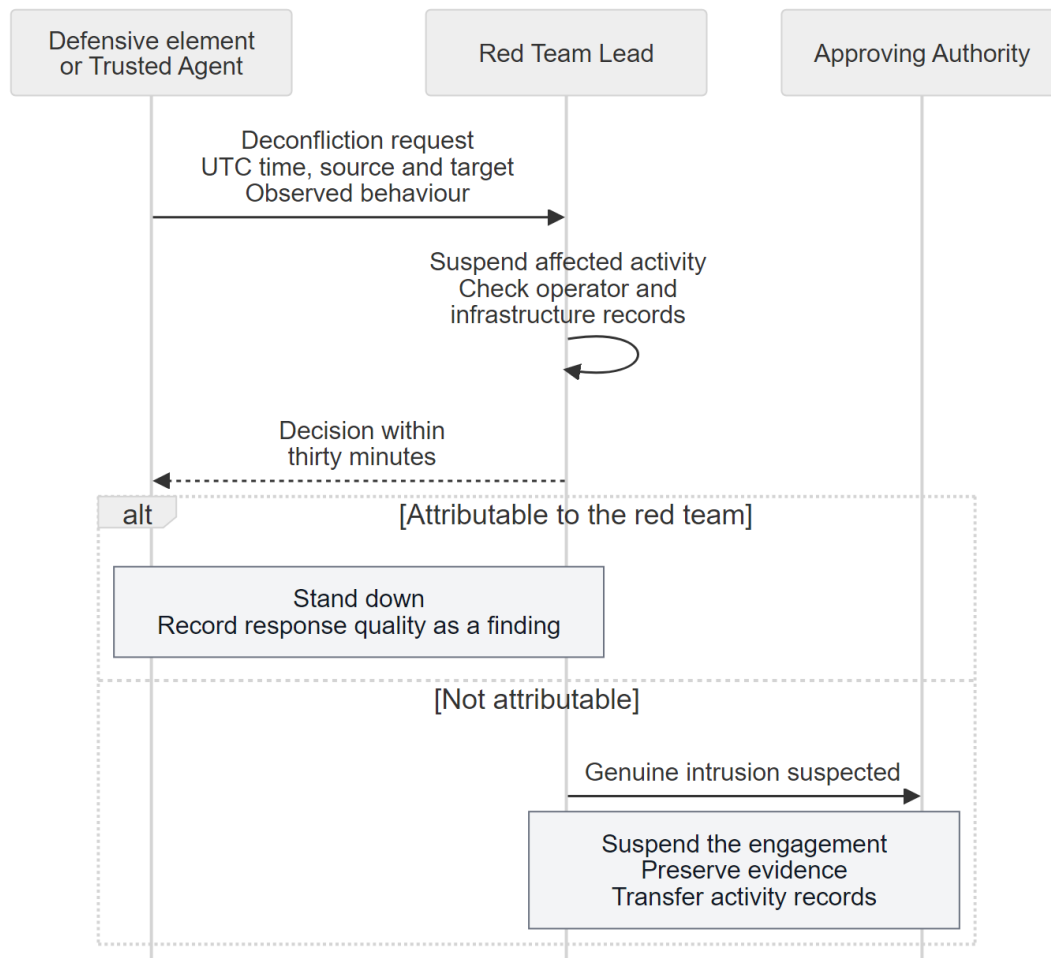


Figure 3. Deconfliction procedure

7.10 A determination of probable attribution is not permitted. Where the records do not establish attribution to the red team, the activity shall be treated as a genuine intrusion until established otherwise.

7.11 The full procedure, including the authentication code word and the maximum permitted interval without contact, is at Annex E.

CHAPTER 8 — STANDING INSTRUCTIONS

8.1 The requirements in this chapter are mandatory and apply to every engagement. Supporting detail is at Annexes B, E and G.

Before commencement

8.2 Activity shall not commence until Rules of Engagement are signed. Verbal authority is not sufficient.

8.3 Activity shall not commence until a Letter of Authorisation is signed by each System Authority competent to consent to access to the systems and facilities in scope. The Approving Authority countersigns where operational risk authority is held separately. The authority and any outcome conflict are verified and recorded; title alone is not evidence of authority.

8.4 Every contact in the Rules of Engagement shall be verified by telephone within twenty-four hours before commencement.

8.5 Every operator shall have read the Rules of Engagement and confirmed that fact in writing.

8.6 No tool or technique shall be introduced into a target environment before it has been tested in a representative laboratory environment. Where planned activity can change system state, the system owner shall also confirm that the relevant backup or restoration method is available and has an accountable operator.

8.7 The red team shall be able to suspend all activity within fifteen minutes of instruction.

During execution

8.8 Membership of the authorised target space shall be verified before every action. Where membership is ambiguous, the target is outside scope.

8.9 Records shall be made at the time of the action and not reconstructed subsequently. Unsuccessful actions shall be recorded; they constitute evidence that a control functioned.

8.10 A second operator shall be consulted before exploitation, before the first use of any tool in the environment, and before any irreversible action.

8.11 Impact shall be demonstrated and not exploited. Reachability of a system is demonstrated without removal of its contents.

8.12 Personal, medical, financial and classified data shall not be exfiltrated. Production data shall not be modified or deleted, save for a marked, reversible artefact recorded in the cleanup register.

8.13 Command and control traffic shall be encrypted. Every modification to a system shall be recorded at the time it is made.

8.14 Errors shall be reported immediately. Concealment of an error is a disciplinary matter; the error itself is not.

Cessation of activity

8.15 Activity shall cease immediately, and the Trusted Agent shall be informed by telephone, on any of the following.

- a. Degradation or loss of a service is suspected, whether or not caused by the red team.
- b. The integrity or availability of production data is at risk.
- c. Exposure of sensitive data exceeds the requirement of proof.
- d. Activity may have reached a system outside the authorised target space.
- e. A third party may be affected.
- f. Evidence of a genuine, unrelated intrusion is identified.
- g. A defensive element has initiated genuine incident response.
- h. Law enforcement, a regulator or an external body becomes involved.
- i. A legal, privacy, safety or personnel concern arises.
- j. An operator is uncertain whether an action is permitted.
- k. Contact with the Trusted Agent is lost beyond the interval set in the Rules of Engagement.

1. An operator has made an error whose consequences are not fully understood.

8.16 Any operator, the Red Team Lead, the Trusted Agent or the Approving Authority may require cessation. No justification is required and none shall be sought. Resumption requires written authority from the Trusted Agent.

On completion

8.17 Every modification shall be removed and its removal verified by a second person. Any item that cannot be removed shall be transferred in writing to a named owner and remains an open item.

8.18 All engagement infrastructure shall be decommissioned, with records preserved beforehand. Command and control shall be deactivated; scope and date kill switches shall be verified; test accounts, keys, tokens and secure channels shall be removed, revoked or restored; captured credentials shall be destroyed or reset; and each action shall be recorded. Backup and snapshot owners shall be told how to prevent later restoration of test malware, tooling or persistence.

8.19 A timestamped record of all red team activity, including source addresses, shall be provided to the Trusted Agent for reconciliation against defensive telemetry.

Conduct of personnel

8.20 Where realism conflicts with the safety of personnel, systems, data or operational readiness, realism yields.

8.21 Reporting shall be truthful, and shall include errors made by the red team and controls that defeated it. A report omitting the defences that succeeded is inaccurate.

8.22 No individual shall be named as a failure, and no engagement material shall be provided for disciplinary purposes.

8.23 A genuine intrusion shall be declared immediately, irrespective of the effect on the engagement's objectives.

8.24 Activity that is unlawful, unsafe or unethical shall be refused and reported. Refusal on these grounds is protected.

8.25 Capability and knowledge obtained during an engagement shall not be employed outside an authorised engagement.

CHAPTER 9 — ASSESSMENT OF EFFECTIVENESS

Principle

9.1 The red team is an instrument of measurement. Its effectiveness is judged by the improvement of the defence and not by its own performance during engagements. Definitions and methods of calculation are at Annex F.

Measures

9.2 The following are recorded for every engagement.

Category	Measures
Timing	Time to telemetry, alert, examination, containment and recovery; assessed presence
Coverage	Planned actions attempted, substituted, blocked or executed; applicable actions producing telemetry, alert, investigation, containment and recovery
Outcome	Objectives achieved and prevented; controls that engaged; findings by severity
Remediation	Findings closed by retest; time to closure; rate of recurrence
Social engineering	Rate of reporting by personnel and time to first report. Individual results are not recorded.

9.2.1 Every reported measure shall state its purpose, exact numerator and denominator or start and end events, data source, owner, exclusions, sample size, missing data and material limitations. An action that was not detected, investigated or contained is recorded as not observed within the test window; it is not assigned a duration of zero. Means are used only where the sample supports them. Event-level values, medians, ranges and counts are preferred for small samples.

9.3 Coverage gaps shall be reported in three categories. They carry different owners and remediation paths; a single figure for detection coverage does not permit command to act.

Category	Primary owner	Required decision
No usable telemetry	Platform, identity or endpoint engineering	Establish or repair the source and validate its data quality
Telemetry present, no effective detection	Detection engineering	Design and validate detection against replay
Alert generated, not examined in the required window	Defensive operations management	Correct priority, routing, capacity or procedure and re-exercise

9.4 Recurrence is a principal programme measure where engagements are materially comparable. Where a finding recurs, remediation may have been ineffective, incomplete in scope, or expressed in terms on which no owner could act. The cause shall be established rather than inferred from the count alone.

Reporting to command

9.5 A single-page report shall be submitted to the Approving Authority quarterly, covering engagements conducted, comparable coverage results, the gap categories at paragraph 9.3 with owners, findings raised, closed, overdue and accepted, validated recurrence, defensive improvements attributable to red team activity, material data limitations, and decisions required. Where cases are not comparable, they are presented separately and not as a trend.

Maturity

9.6 Capability maturity is assessed annually across four domains, being programme, personnel, process and technology, at three levels. The model is at Annex F.

9.7 Development of custom tooling shall not be undertaken before the process domain has reached the second level. Tooling capability in an organisation without an established retest cycle does not improve defensive outcomes.

CHAPTER 10 — RESOURCES AND COMMAND COMMITMENTS

Resources

10.1 The capability requires the following.

- a. An establishment matched to paragraph 6.7. Two delivery personnel are sufficient to start safely with open, collaborative activity; three are the minimum delivery cell for a covert live engagement; six to nine are the target for a sustainable multi-engagement programme. Control and authorisation appointments remain outside those figures.
- b. A laboratory environment representative of the production estate. This is the principal material requirement and the precondition for the standing instruction at paragraph 8.6.
- c. Controlled operator systems and engagement infrastructure.

10.2 The assessed organisation is required to provide approximately two days of the Trusted Agent's time per week of execution, one day of each system owner during scoping, and four hours of the defensive element for the debrief.

10.3 The principal cost of the capability is remediation. Findings raised require resourcing. A capability producing findings that are not resourced produces no improvement.

Annual programme

10.4 The annual programme shall be chosen from the tier the team can sustain while completing cleanup, reporting, remediation support and retest. The table is a planning ceiling, not a quota.

Tier	Sustainable programme
Two-person startup	One narrow purple exercise each quarter; one open assumed-breach assessment in the first year; retest before new scope is accepted
Three to five personnel	Four to six purple exercises, two scoped engagements and one threat-led engagement per year; quarterly portfolio review
Six to nine personnel	Monthly purple activity; one scoped engagement per quarter; two threat-led engagements and one external exercise per year; half-yearly revalidation

Every tier conducts the annual maturity assessment and review of this publication. Tempo shall be reduced when open remediation, fatigue, leave, training or loss of a backup role makes the next engagement unsafe or unreviewable.

Command commitments

10.5 Effective conduct of red team activity requires the following of command.

- a. Appointment of an Approving Authority holding genuine authority and situated outside the chain of command assessed.
- b. Acceptance that findings will be unwelcome, and that the framing of engagements is learning rather than examination.
- c. Resourcing of remediation.
- d. Maintenance of the independence controls at paragraph 5.9, in particular sub-paragraph 5.9.c.
- e. Undertaking that engagement material shall not be employed for disciplinary purposes. Where personnel believe that an engagement may affect their position, the organisation ceases to provide accurate information and the capability ceases to have value.

Risks accepted

10.6 The following risks are accepted by command on approval of an engagement, and are controlled as shown.

Risk	Control
Disruption of a service	Trusted Agent suspension authority; cessation criteria; exclusion list; risk assessment
A data protection incident caused by the assessment	Minimisation; use of markers in place of live data; specification of prohibited proof
Findings becoming a matter of external scrutiny	Agreed distribution; classification; formal acceptance of risk
Damage to the standing of defensive personnel	Prohibition on naming individuals; reporting of controls that functioned
Expenditure producing no improvement	Remediation tracking; retest; purple replay; quarterly reporting

10.7 Each of these risks is controlled by procedure rather than by technical measure.

CHAPTER 11 — GOVERNANCE

Structure of the publication

11.1 The publication is issued in two tiers.

Tier	Amendment	Authority
This publication	Amendment to a requirement expressed as “shall” requires re-signature	Approving Authority
Annexes and pro formas	Amended as practice and technology require	Head of Red Team, notified to the Approving Authority

11.2 Content subject to change, including tooling, techniques, infrastructure and technique tables, is held in the annexes so that this publication does not require re-signature on its amendment.

Review

11.3 This publication is reviewed annually, and additionally following any of the following.

- a. An engagement producing a lessons-learned item marked as requiring amendment.
- b. An incident in which red team activity caused unintended impact, or raised a legal, security or classification question.
- c. Material change to the legal environment, the mandate, or the classification regime.

Exceptions

11.4 An exception to a requirement expressed as “shall” requires written, specific and time-limited approval from the Approving Authority, naming the compensating control in force. No exception may create self-authorisation, remove system-owner consent, expand an unsigned scope, combine the Red Team Lead and Trusted Agent, remove independent report review, weaken a cessation criterion, override a legal, safety or ethical refusal, or permit activity prohibited by applicable law, contract or provider policy. Nor may an exception waive a role combination designated non-waivable at paragraph 6.5 or an absolute prohibition at Annex B.

11.5 Exceptions are recorded in the Rules of Engagement for the engagement concerned and are examined at the annual review. Standing or open-ended exceptions are not permitted.

Escalation

11.6 Disputes are resolved as follows.

Matter	Resolution
Between the Red Team Lead and the Trusted Agent	Approving Authority
Severity of a finding	Recorded as a dispute, with both positions stated in the report
Remediation or acceptance of risk	Approving Authority, in writing, with a review date
Refusal on legal, safety or ethical grounds	Not subject to override. Escalated to the Approving Authority and recorded.

Independent assurance

11.7 After the first covert live engagement, and at least annually while that service is active, a qualified person outside the delivery cell shall sample one completed engagement and the programme controls. For a small team this person may come from internal audit, legal, risk, security assurance or an external specialist, provided competence, clearance and independence are recorded.

11.8 The review does not repeat offensive activity. It verifies, at minimum: authority and positive scope; role separation; provider and third-party permissions; gate evidence; threat-to-action traceability; operator and evidence records; cessation and deconfliction; cleanup and restoration; report claims; measure quality; finding ownership; risk acceptance; retest; exceptions; repository access and destruction. Results and corrective actions are reported to the Approving Authority and tracked to verified closure.

LEXICON

Abbreviations

ATT&CK	Adversarial Tactics, Techniques and Common Knowledge (MITRE)
C2	Command and control
CBEST	Bank of England intelligence-led security testing framework
CTI	Cyber threat intelligence
DORA	Digital Operational Resilience Act, Regulation (EU) 2022/2554
GDPR	General Data Protection Regulation, Regulation (EU) 2016/679
LoA	Letter of Authorisation
NCSC	United Kingdom National Cyber Security Centre
NIST	United States National Institute of Standards and Technology
ROE	Rules of Engagement
SITREP	Situation report
TIBER-EU	Threat Intelligence-based Ethical Red Teaming framework for the European Union
TLPT	Threat-led penetration testing
TTP	Tactics, techniques and procedures
UTC	Coordinated Universal Time

Terms and definitions

activity record. The consolidated, time-ordered account of red team activity produced by reconciling operator, infrastructure, session and tool records. It includes source, target and stable action identifiers and is transferred at culmination.

adversary emulation. Replication of the documented techniques of a named threat actor, sequenced consistently with that actor's observed behaviour.

Approving Authority. The appointment accepting the risk of an engagement and signing the Letter of Authorisation.

assessment objective. One or more of the four defensive outcomes at paragraph 3.3: Protect, Detect, Respond and Restore. It states what the engagement is intended to assess; it is distinct from the engagement objective that states the end condition to be reached.

assumed breach. A starting posture in which initial access is granted by agreement, so that the engagement assesses events following compromise rather than the obtaining of compromise.

attack path. An ordered or branching sequence of authorised actions by which a scenario may progress from its starting posture to an objective.

authorised target space. The systems, networks, identities, personnel groups and locations against which activity is permitted, defined in the Rules of Engagement. Anything not within it, and anything of uncertain status, is outside scope.

capability level. The level of adversary capability emulated under Annex B, paragraph B.7. It describes the adversary represented, not the maturity or skill of the red team.

cleanup register. The controlled record of every system modification, artefact, credential, channel and engagement-infrastructure item requiring removal, transfer or verified disposition at culmination. Pro forma T12 is used.

Control Team. The small group within the assessed organisation, led by the Trusted Agent, that knows of and controls a covert engagement. Earlier publications may call this the White Team.

covert engagement. An engagement conducted without advance knowledge of the defensive element being assessed. The Trusted Agent and any supporting Control Team remain informed.

deconfliction. The process of establishing whether observed activity originates from the red team or from a genuine adversary.

defensive element. The personnel and functions responsible for detecting and responding to intrusion. Referred to elsewhere as the blue team.

engagement. A single authorised assessment, conducted under one set of Rules of Engagement and one Letter of Authorisation, through the phases at Chapter 7.

evidence. An artefact or record retained with sufficient provenance and integrity to support an engagement claim. It is not represented as forensic evidence or as having a formal chain of custody unless the required controls were applied.

finding. An evidenced weakness or control gap, stated with its root cause, risk, affected scope, recommended control, owner and method of retest. Risk acceptance does not close a finding; closure requires a passed retest.

flag. A marker of no intrinsic value, placed in a target location by the Trusted Agent and retrieved to demonstrate access without access to live data.

gate. The named decision at the end of a lifecycle phase that passes the engagement forward, returns it for correction, or stops it, using the criteria in Annex C.

Get In, Stay In, Act. The three stages of execution defined at paragraph 7.8.

golden thread. Stable traceability from the service at risk and supporting threat evidence through scenario, objective, action, defensive observation, finding, remediation and retest.

Head of Red Team. The standing appointment owning the capability, its personnel, standards and annexes.

Legal Adviser. A qualified adviser responsible for determining the legal instruments, constraints and reviews applicable to the organisation and engagement. Advice does not by itself grant authority to access a target.

Letter of Authorisation. The short instrument recording target-specific consent and the authority under which activity is conducted, held by every operator for the duration of an engagement. It does not replace other legal, contractual or provider requirements.

objective. A defined and verifiable end state demonstrating mission impact.

operational risk authority. The person or body competent to accept the potential operational consequences and residual risk of an engagement. This is normally the Approving Authority and may be distinct from the System Authority.

operator. A red team member assigned to conduct authorised activity and maintain the contemporaneous record of their own actions and decisions.

operator record. The contemporaneous account of an operator's action, rationale, expected and actual result, source and target, evidence identifiers and any modification made. Pro forma T05 is used.

purple team exercise. Collaborative activity conducted openly with defensive elements, technique by technique, to establish and validate detections.

read-across. A structured assessment of whether a finding or lesson also applies to comparable services, systems or control implementations outside the tested scope.

red team. An element with sufficient organisational and functional independence to challenge an organisation from the perspective of an adversary in order to improve that organisation's effectiveness.

Red Team Lead. The appointment responsible for the conduct of one engagement.

retest. Authorised repetition of the relevant procedure, or equivalent verification, to establish whether remediation corrected the finding without unacceptable adverse effect.

Reviewing Officer. A qualified person who did not execute the engagement or author its report and who independently verifies the report before release.

Rules of Engagement. The document governing the conduct of a single engagement.

scenario. A threat-informed design combining an adversary premise, starting posture, objectives, attack paths, decision points, constraints and safety measures.

Security Authority. The appointment responsible under applicable organisational policy for classification, security handling and release review of sensitive or classified material.

System Authority. The person or body competent to consent to access to a particular system, identity, network, facility or other target. Authority to direct an assessment does not by itself confer System Authority.

system owner. The role accountable for the operation and protection of a system. A system owner is not assumed to hold authority to consent to access unless also designated as the System Authority.

threat profile. A structured description of the adversary emulated during an engagement.

Trusted Agent. The Control Team Lead within the assessed organisation, controlling the engagement and holding unilateral authority to suspend or terminate it.
